Data Protection and Information Security Policy v2.4

Apex Solutions Ltd.

Document ID	DOC-2024-0042	**Classification**	Internal – Confidential
Effective Date	January 15, 2025	**Review Date**	January 15, 2026
Document Owner	Sarah Chen, Chief Information Security Officer	**Version**	2.4

Table of Contents

1. Purpose and Scope	1.1 – 1.4	3
2. Data Classification	2.1 – 2.5	3
3. Access Control	3.1 – 3.6	4
4. Data Encryption Standards	4.1 – 4.3	5
5. Incident Response	5.1 – 5.5	5
6. Third-Party Risk Management	6.1 – 6.3	6
7. Employee Training and Awareness	7.1 – 7.2	6
8. Policy Compliance and Enforcement	8.1 – 8.3	7
Document Approval		7

Section 1: Purpose and Scope

1.1 Purpose

This policy establishes the requirements for protecting organizational and customer data held or processed by Apex Solutions Ltd., ensuring confidentiality, integrity, and availability across all systems, applications, and physical environments.

1.2 Scope

This policy applies to all employees, contractors, temporary staff, and third-party vendors who access, store, transmit, or otherwise process organizational or customer data, regardless of location or device used.

1.3 Regulatory Alignment

This policy is designed to support compliance with the General Data Protection Regulation (GDPR), the ISO 27001 information security management standard, and SOC 2 Trust Services Criteria. Where conflicts arise between this policy and applicable law, the stricter requirement shall govern.

1.4 Policy Ownership

The Chief Information Security Officer (CISO) is accountable for the maintenance, periodic review, and enforcement of this policy.

Section 2: Data Classification

2.1 Classification Categories

All organizational data must be classified into one of four categories: Public, Internal, Confidential, or Restricted, based on sensitivity and potential business impact if disclosed.

2.2 Handling Requirements

- Public: May be freely shared outside the organization with no restrictions.
- Internal: Restricted to employees and authorized contractors; not for external distribution.
- Confidential: Access limited to individuals with a defined business need; encryption required in transit.
- Restricted: Highest sensitivity tier; access limited to named individuals with explicit authorization and full encryption at rest and in transit.

2.3 Labeling and Marking

All documents and datasets must be marked with their classification level in the header or footer, and electronic records must carry classification metadata where supported by the system.

2.4 Data Retention

Retention periods are defined per classification: Public data may be retained indefinitely; Internal data for 5 years; Confidential data for 3 years unless otherwise required by contract or law; Restricted data for 1 year following the end of its business purpose, subject to legal hold exceptions.

2.5 Reclassification

Data owners must review classification levels annually or upon material change in business context, and reclassify records accordingly.

Section 3: Access Control

3.1 Principle of Least Privilege

Access to systems and data must be limited to the minimum level necessary for an individual to perform their assigned job function.

3.2 Role-Based Access Control

Access permissions must be assigned through defined roles (RBAC) rather than granted individually, and role definitions must be reviewed and approved by system owners.

3.3 Multi-Factor Authentication

Multi-factor authentication (MFA) is mandatory for all remote access to organizational systems, including VPN, cloud administration consoles, and email.

3.4 Access Review Cycle

User access rights must be reviewed on a quarterly basis by system owners and confirmed as still appropriate to the individual's current role.

3.5 Privileged Access Management

Privileged accounts must be provisioned through a dedicated privileged access management (PAM) solution, with session logging and just-in-time elevation where technically feasible.

3.6 Deprovisioning

All system and application access must be revoked within 24 hours of an employee's or contractor's termination or contract end date.

Section 4: Data Encryption Standards

4.1 Encryption at Rest

All Confidential and Restricted data stored on organizational systems must be encrypted using AES-256 or an equivalent approved algorithm.

4.2 Encryption in Transit

All data transmitted across public or untrusted networks must be protected using TLS 1.3 or a later approved version.

4.3 Key Management

Encryption keys must be managed through an approved key management system and rotated on a 90-day cycle, or immediately upon suspected compromise.

Section 5: Incident Response

5.1 Detection and Reporting

All suspected security incidents must be reported to the Security Operations team immediately upon discovery through the designated incident reporting channel.

5.2 Severity Classification

Incidents must be classified as Critical, High, Medium, or Low based on scope of impact, data sensitivity involved, and business disruption.

5.3 Notification Timelines

For incidents classified as Critical involving personal data, regulatory authorities must be notified within 72 hours of confirmed discovery, and affected individuals must be notified within 24 hours where required by law or contract.

5.4 Post-Incident Review

A formal post-incident review must be completed within 14 days of incident closure, documenting root cause, remediation actions, and lessons learned.

5.5 Evidence Preservation

All logs, system images, and other artifacts relevant to an incident must be preserved in accordance with the organization's evidence handling procedures to support forensic analysis and potential legal proceedings.

Section 6: Third-Party Risk Management

6.1 Vendor Security Assessment

All third-party vendors must undergo a security assessment prior to onboarding, covering data handling practices, certifications, and prior incident history.

6.2 Annual Audits

Vendors classified as critical to business operations or with access to Confidential or Restricted data must undergo an annual independent security audit.

6.3 Contractual Obligations

All vendor contracts must include data protection obligations consistent with this policy, including breach notification requirements and the right to audit.

Section 7: Employee Training and Awareness

7.1 Annual Security Awareness Training

All employees and contractors must complete mandatory security awareness training annually, covering data handling, phishing recognition, and incident reporting procedures.

7.2 Phishing Simulation

Phishing simulation exercises must be conducted on a quarterly basis, with results used to identify and remediate training gaps.

Section 8: Policy Compliance and Enforcement

8.1 Compliance Monitoring

Compliance with this policy will be monitored through periodic audits, automated control monitoring, and management review.

8.2 Disciplinary Actions

Violations of this policy may result in disciplinary action up to and including termination of employment or contract, consistent with the organization's disciplinary procedures.

8.3 Policy Exceptions

Any exception to this policy must be documented, risk-assessed, and formally approved by the CISO prior to implementation.

Document Approval

Role	Name	Signature	Date
Prepared By	Sarah Chen, CISO		
Reviewed By			
Approved By			